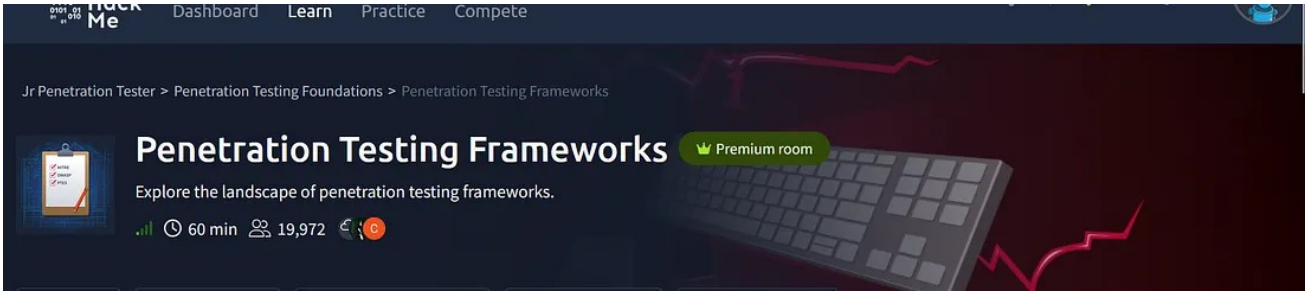
Open in app ↗

Medium

Access to everything. Now 30% off. Upgrade now



Pen Testing Frameworks

Penetration Testing Frameworks “TRYHACKME WALKTROUGH”

30 min read · Just now

Nuh hozar

Listen Share More

Task 1- Imagine you just landed your first penetration testing engagement. The client is a mid-size e-commerce company, and they want you to evaluate the security of their web application, internal network, and employee security awareness. You sit down, open your laptop, and then what? Do you start running `nmap` right away? Do you test the login page for SQL injection first? Do you try phishing an employee?

Without a structured approach, a penetration test quickly becomes a disorganized collection of random checks. You might miss critical attack surfaces, skip important documentation, or deliver findings that the client cannot act on. Worse, you might test systems that were never in scope and find yourself in legal trouble. This is exactly the problem that **penetration testing frameworks** solve.



A penetration testing framework is a structured methodology that guides security professionals through every stage of an engagement, from initial planning and scoping to exploitation, reporting, and remediation validation. Consider the analogy of a building inspector following a code-compliance checklist: the inspector does not wander through the building, hoping to notice problems. Instead, they follow a systematic process that ensures every structural element, electrical system, and fire safety measure is evaluated against a known standard. Penetration testing frameworks serve the same purpose for security assessments.

Relying on a structured methodology provides several benefits. It ensures **thoroughness** so that critical areas are not overlooked. It promotes **consistency**

so that different testers on the same team produce comparable results. It supports **compliance** by aligning the assessment with regulatory requirements. It also improves **communication** because clients, auditors, and stakeholders can understand and trust a process grounded in a recognized standard.

There are many penetration testing frameworks in active use today, and each has its own philosophy, strengths, and ideal use cases. In this room, we will explore the following in depth:

1. Open Source Security Testing Methodology Manual (OSSTMM), a scientific, metrics-driven approach to security testing
2. OWASP Web Security Testing Guide (WSTG), the go-to framework for web application assessments
3. NIST Special Publication 800–115, the U.S. government’s technical guide to security testing and assessment
4. Penetration Testing Execution Standard (PTES), a practical, phase-driven standard that mirrors how real engagements are conducted
5. Information Systems Security Assessment Framework (ISSAF), a historically influential methodology with a detailed nine-step assessment model

We will also introduce MITRE ATT&CK as a complementary knowledge base that maps adversary tactics and techniques. We will survey several other notable frameworks, including the WASC Threat Classification, CSA Cloud Controls Matrix, OWASP Mobile Application Security Testing Guide (MASTG), PCI DSS Penetration Testing Guidelines, and the CBEST Framework, so you know when and where they apply.

Learning Objectives

- Describe the purpose and structure of the major penetration testing frameworks.
- Compare frameworks based on their scope, methodology, and intended use cases.
- Select an appropriate framework for a given engagement scenario.

- Explain how MITRE ATT&CK complements traditional penetration testing methodologies.

Prerequisites

- Familiarity with basic networking concepts
- A general understanding of what penetration testing involves

Answer the questions below

Q 1- A penetration tester runs several tools against a target but skips network mapping entirely and does not document the scope beforehand. Which benefit of using a framework would have most directly prevented this situation?

Answer : Thoroughness

Q 2- Your client operates in the healthcare sector and must demonstrate compliance with HIPAA. Beyond identifying vulnerabilities, which benefit of using a recognized framework would matter most to this client?

Answer : Compliance

Task 2- OSSTMM

Overview

You have probably heard the phrase “you can’t manage what you can’t measure.” In most engineering disciplines, quantification is a given: a structural engineer does not declare a bridge “safe” based on intuition. Yet in penetration testing, findings are often delivered as subjective narratives. The **Open Source Security Testing Methodology Manual (OSSTMM)** aims to change that.

Developed by the **Institute for Security and Open Methodologies (ISECOM)**, the OSSTMM (currently at **version 3**) applies the scientific method to security testing. Its defining characteristic is **metrics over opinions**: rather than delivering subjective risk judgments, OSSTMM produces quantifiable, verifiable, and repeatable results.

OSSTMM organizes testing around five **security channels**, reflecting its philosophy that security is not just a network problem:

- **Human Security (HUMSEC):** Social engineering and human-factor vulnerabilities.
- **Physical Security (PHYSSEC):** Physical access controls, from badge readers to tailgating.
- **Wireless Communications (SPECSEC):** Wi-Fi, Bluetooth, RFID, and other electromagnetic signals.
- **Telecommunications (COMSEC):** Phone systems, VoIP, fax, and modem infrastructure.
- **Data Networks (DATASEC):** Network services, firewalls, and application-layer protocols.

An organization might have flawless firewall rules, but if an attacker can tailgate into the server room (PHYSSEC) or social-engineer a credential reset (HUMSEC), those network controls become irrelevant. The five channels ensure nothing is overlooked.

At the heart of OSSTMM’s quantitative approach are **Risk Assessment Values (RAVs)**. A RAV measures the balance between the total attack surface (exposure) and the controls protecting it. A positive RAV indicates residual risk; a RAV near zero suggests controls are well-matched to exposure. This numeric output means that two testers assessing the same target should arrive at comparable results, much as two engineers measuring the same beam should calculate similar stress tolerances.

Phases: A Walkthrough

The OSSTMM testing cycle has four phases. Let’s walk through them using a scenario: your team is assessing the external network of **FinVault Corp**, a financial services company, scoped to `10.0.113.0/24` and their customer portal at `portal.finvault-corp.thm`.

Phase 1: Induction covers enumeration and verification. You map what exists and

confirm it is real. At FinVault, you query DNS, review certificate transparency logs, and discover subdomains like `vpn.finvault-corp.thm` and `mail.finvault-corp.thm`. You then verify each asset is live and responsive. The output is a confirmed inventory of the target environment.

Phase 2: Interaction covers qualification and quantification. You actively probe the verified assets and assess their relevance. At FinVault, you connect to each service, fingerprint its technology, and quantify the exposure: 12 externally reachable services across 8 hosts, 4 of which accept unauthenticated connections. These findings feed directly into the attack surface calculation.

Phase 3: Inquiry covers privilege escalation and verification escalation. You test whether the measured exposure can be converted into unauthorized access. At FinVault, you discover an IDOR vulnerability in the customer portal that allows one authenticated user to read another customer’s account statements. Verification escalation confirms the scope: read access to 12,000 accounts, no write access.

Phase 4: Intervention covers quarantine, audit, and enticement. You address findings and examine the broader control environment. At FinVault, the vulnerable endpoint is restricted. At the same time, a patch is developed (quarantine), the wider access control model is examined for similar flaws (audit), and a canary token is deployed to test internal detection capabilities (enticement).

Closing Notes

OSSTMM prescribes the **Security Test Audit Report (STAR)** format for deliverables, enforcing consistency and enabling cross-team comparability.

Its scientific rigor is both its greatest strength and its primary barrier. The OSSTMM framework makes results auditable and comparable, which is rare in penetration testing. However, the learning curve is steep, full implementations can be time-consuming, and experienced OSSTMM practitioners are harder to find than those trained in OWASP or NIST methodologies. OSSTMM is best suited for organizations that need repeatable, auditable security measurements and are willing to invest in mastering the methodology.

Answer the questions below

Q 3- What OSSTMM metric quantifies the balance between an organization’s attack surface and its controls?

Answer : Risk Assessment Values

Q 4- During an OSSTMM assessment, you complete **Induction** and **Interaction**, identifying 6 hosts running unpatched services. Which phase do you enter next, and what is the primary objective?

Answer : Inquiry

Task 3- **OWASP WSTG**

Overview

You are testing a web application for an online retailer. The application handles user registration, product search, shopping cart, payment processing, and order tracking. Where do you even begin? Do you test the login form first? The search bar? The payment API? With dozens of potential attack surfaces in a single web application, it is easy to either test the same things twice or miss entire vulnerability classes altogether.

The **Open Web Application Security Project (OWASP)** addresses this problem with the Web Security Testing Guide (WSTG). While OWASP is most widely known for the OWASP Top Ten list of critical web vulnerabilities, the WSTG goes far deeper: it is a comprehensive, community-driven framework that organizes web application testing into **over 90 discrete test cases** grouped across twelve categories.

Those twelve categories span the full attack surface of a modern web application. They include information gathering, configuration and deployment management, identity management, authentication, authorization, session management, input validation, error handling, cryptography, business logic, client-side testing, and API testing. Each category contains numbered test cases (e.g., `WSTG-INPV-01` for reflected cross-site scripting) with step-by-step guidance

on what to test and how to test it.

The WSTG adopts a **risk-based approach**: vulnerabilities are prioritized based on their exploitability and impact, not simply cataloged. This approach means the framework helps testers focus their efforts where they matter most.

Phases: Security Across the SDLC

What sets the WSTG apart from many penetration testing frameworks is that it does not treat security as a single event. Instead, it aligns testing across five phases of the **Software Development Life Cycle (SDLC)**, embedding security from initial planning through post-launch maintenance.

Let’s see how this works for our online retailer, **ShopSecure Inc.**, which is building a new customer portal.

Phase 1: Before development begins. Security requirements and regulatory obligations are established upfront. For ShopSecure, this means defining that the portal must comply with **PCI DSS** (since it processes payments) and establishing measurable criteria, such as the maximum acceptable time for patching vulnerabilities.

Phase 2: During definition and design. The application architecture is reviewed for security flaws before any code is written. ShopSecure’s team creates threat models for the payment flow, identifying that the checkout API will be a high-value target and designing rate-limiting and input validation controls from the start.

Phase 3: During development. Code is vetted through walkthroughs and reviews. ShopSecure’s developers review the authentication module against WSTG test cases for credential handling (`WSTG-ATHN`), identifying a flaw in which password reset tokens do not expire.

Phase 4: During deployment. Security controls are verified in the production environment. ShopSecure’s team runs a penetration test against the staged application, verifying that default credentials have been changed, that TLS is properly configured, and that no debug endpoints are exposed.

Phase 5: During maintenance and operations. Security is maintained post-launch through periodic health checks, especially after updates. When ShopSecure

pushes a new product recommendation feature three months later, the relevant WSTG test cases are re-executed to ensure the update has not introduced new vulnerabilities.

Closing Notes

The WSTG’s greatest strength is its **exhaustive, practical coverage**. With over 90 test cases, each containing specific procedures and expected results, it gives testers a concrete roadmap rather than abstract principles. It also benefits from continuous updates from a global community of security professionals, keeping it current with emerging vulnerability classes and modern architectures such as SPAs and microservices.

On the downside, a **full implementation of every test case can be impractical** for resource-constrained teams. Some tests require specialized expertise in areas like cryptographic analysis or business logic testing. There is also a risk of falling into a **checklist mentality**, where testers mechanically execute test cases without stepping back to assess the application’s overall risk posture. The best practitioners use the WSTG as a foundation while applying critical thinking beyond the checklist.

Answer the questions below

Q 5- The WSTG organizes its test cases using a specific identifier format. What identifier would you look for to find test cases related to input validation?

Answer : WSTG-INPV

Q 6- A development team has just finished coding a new feature and wants to check it against WSTG before deployment. Which SDLC-aligned phase number are they in?

Answer : 3

Task 4- NIST SP 800–115

Overview

Consider this scenario: you work as a security analyst for a government agency or a large enterprise that contracts with the federal government. Your organization needs a security assessment, but the results must satisfy auditors, comply with federal guidelines, and be defensible in the event of oversight inquiries. A penetration testing report full of informal commentary and subjective risk ratings won’t cut it. You need a methodology that federal regulators recognize and trust.

That is the niche filled by NIST Special Publication 800–115, titled *Technical Guide to Information Security Testing and Assessment*. Published by the **National Institute of Standards and Technology (NIST)**, this document provides a foundational framework for systematically evaluating the security posture of information systems. While it originated in the U.S. federal context, its principles are broadly applicable and widely adopted in the private sector, especially by organizations that value structured, repeatable processes.

NIST SP 800–115 is not a penetration testing framework in the narrow sense. It is broader: it covers the full spectrum of **security testing and assessment techniques**, from document reviews and log analysis to vulnerability scanning and full penetration tests. It treats penetration testing as one technique among several, all of which serve the goal of validating whether security controls work as intended.

Three core objectives drive the framework. First, **identify vulnerabilities** in systems, networks, and applications. Second, **validate security controls** by testing whether they perform as expected under adversarial conditions. Third, **assess exploitability** by simulating real-world attack scenarios to determine whether a threat actor can actually leverage identified weaknesses.

Phases: A Walkthrough

NIST SP 800–115 structures testing into three phases. Let’s walk through them with a scenario: your team has been engaged to assess the security of **GovNet**, a mid-size federal agency’s internal network spanning 500 hosts, 3 data centers, and a public-facing citizen services portal.

Phase 1: Planning. Before any testing begins, the objectives, scope, and rules of engagement are formally defined and documented. For GovNet, this means

specifying which network segments are in scope (the citizen portal and its supporting backend) and which are excluded (the classified enclave). It also means establishing communication protocols: who gets notified if a critical vulnerability is found mid-test, what hours testing is permitted, and what constitutes an emergency stop condition. The planning phase produces a formal test plan that all stakeholders sign off on.

Phase 2: Execution. This is where active testing happens. NIST SP 800–115 groups execution activities into four technique categories:

- **Review techniques**: Examining documentation, policies, system configurations, and rule sets. At GovNet, this includes reviewing firewall rules and access control lists for misconfigurations.
- **Target identification and analysis**: Discovering and fingerprinting live hosts, open ports, and running services. At GovNet, you scan the citizen portal’s infrastructure and identify 12 internet-facing services.
- **Target vulnerability validation**: Confirming that identified weaknesses are real and exploitable, not false positives. At GovNet, a scan flags a potential SQL injection on the portal’s search function; you manually validate it by crafting a test query that returns database version information.
- **Penetration testing**: Simulating adversarial attacks to test the depth of exploitation possible. At GovNet, you chain the confirmed SQL injection with a privilege escalation on the database server to demonstrate that an external attacker could access internal citizen records.

Notice how NIST SP 800–115 treats these as a progression from passive to active, from low-impact to high-impact. Not every engagement needs to reach the penetration testing stage; sometimes, a review and vulnerability validation are sufficient for the assessment’s objectives.

Phase 3: Post-Testing. The focus shifts to analyzing results, prioritizing risks, and delivering actionable remediation strategies. For GovNet, this means categorizing findings by severity (the SQL injection chain is critical; a missing HTTP security header is low), mapping each finding to the specific control it bypasses, and providing concrete remediation steps. NIST SP 800–115 emphasizes that findings

should be **actionable**: telling a client “you have a SQL injection” is not enough; explaining which parameter is vulnerable, what data is at risk, and how to remediate it is the standard.

Closing Notes

NIST SP 800–115’s strengths lie in its **flexibility and institutional credibility**. It adapts to diverse environments, from traditional data centers to cloud infrastructure and IoT deployments, because it defines technique categories rather than prescribing specific tools. Its association with NIST gives it immediate recognition in government, defense, and regulated industries. It also promotes standardization, making it easier for organizations with multiple testing teams to maintain consistent quality.

On the downside, it **does not enforce audit frequencies or penalties**. Unlike PCI DSS, which mandates annual penetration tests, NIST SP 800–115 is guidance, not regulation. This can limit its adoption as a standalone driver in highly regulated sectors. It also requires skilled personnel; the framework assumes testers can execute the full range of techniques from document review to exploitation, which demands a broad skill set.

Answer the questions below

Q 7- During the Execution phase, your vulnerability scanner flags 15 potential issues on a web application. Before attempting exploitation, which NIST SP 800–115 technique category should you apply to these findings?

Answer : Target vulnerability validation

Task 5- PTES

Overview

You have now seen frameworks that emphasize scientific metrics (OSSTMM), web application coverage (OWASP WSTG), and government-aligned assessment techniques (NIST SP 800–115). But here is a question worth considering: if you were hired tomorrow for a standard penetration testing engagement against a

corporate network, which framework would most closely mirror the actual workflow you would follow from the first client call to the final report delivery?

For many working pentesters, the answer is the **Penetration Testing Execution Standard (PTES)**. Available at pentest-standard.org, PTES was developed by a group of experienced security practitioners with a specific goal: to define what a real penetration test looks like, end-to-end. Where other frameworks focus on *what* to test or *how* to measure, PTES focuses on *how the engagement flows* from start to finish.

PTES is organized into **seven phases** that map directly to the lifecycle of a penetration testing engagement. This approach makes it exceptionally practical for junior testers because it answers the question that many frameworks leave implicit: “I have a signed contract; now what do I do on day one, day two, and every day after?”

Phases: A Walkthrough

Let’s walk through the seven phases using a scenario: a healthcare company, **MedGuard Health**, has hired your team to perform a full penetration test of their corporate network and patient records portal.

Phase 1: Pre-Engagement Interactions. This is everything that happens before testing begins. You define the scope with MedGuard’s IT director: the corporate LAN (`10.10.0.0/16`), the patient portal at `records.medguard-health.thm` , and wireless networks at the headquarters building. You document the rules of engagement, including testing windows (weeknights only to avoid disrupting clinical operations), emergency contacts, and a "get out of jail free" letter authorizing the test. PTES is notably detailed here because unclear scoping is the number one source of legal and professional disputes in penetration testing.

Phase 2: Intelligence Gathering. You collect information about MedGuard using both passive and active techniques. Passive reconnaissance includes harvesting employee email addresses from LinkedIn, discovering subdomains through certificate transparency logs, and reviewing job postings that reveal technology stacks (“seeking a DBA with Oracle 19c experience”). Active reconnaissance involves DNS enumeration and network scanning within the agreed scope. PTES distinguishes between these levels because the depth of intelligence gathering directly shapes the quality of the subsequent phases.

Phase 3: Threat Modeling. Using the intelligence gathered, you identify the most valuable targets and the most likely attack paths. At MedGuard, the patient records database is the highest-value asset. Your threat model identifies two primary attack paths: compromising the patient portal directly through a web vulnerability, or pivoting through the corporate LAN after compromising an employee workstation. This phase ensures your testing effort is directed by adversarial logic rather than random scanning.

Phase 4: Vulnerability Analysis. You systematically identify weaknesses that could enable the attack paths from your threat model. At MedGuard, vulnerability scanning reveals that the patient portal is running an outdated version of Apache Tomcat, which contains a known deserialization vulnerability. On the internal network, several workstations are missing critical patches. PTES emphasizes that vulnerability analysis includes both automated scanning and manual verification to eliminate false positives.

Phase 5: Exploitation. You attempt to exploit the confirmed vulnerabilities. At MedGuard, you exploit the Tomcat deserialization flaw to gain a shell on the portal server. On the internal side, you use a phishing pretext (authorized in the scope) to deliver a payload to an employee workstation. PTES stresses that exploitation should be purposeful: the goal is to demonstrate business impact, not to “pop boxes” for the sake of it.

Phase 6: Post-Exploitation. After gaining access, you determine the real-world impact. From the compromised portal server, you pivot into the backend database and confirm read access to patient records. From the employee workstation, you extract cached domain credentials and demonstrate lateral movement to a file server containing financial data. PTES treats post-exploitation as the phase where technical findings are translated into business risk: “we accessed 50,000 patient records” carries far more weight than “we got a shell.”

Phase 7: Reporting. You deliver the findings in a structured report with two audiences in mind. The **executive summary** communicates business risk in plain language for MedGuard’s leadership: patient data was accessible, regulatory exposure under HIPAA is significant, and remediation is urgent. The **technical report** provides the details that MedGuard’s IT team needs to reproduce and fix

each finding: exact exploitation steps, affected hosts, evidence screenshots, and prioritized remediation guidance.

Closing Notes

PTES’s greatest strength is its **practical, end-to-end structure**. It reads like a playbook for how engagements actually unfold, which makes it an excellent learning framework for junior testers building their workflow instincts. Its detailed treatment of pre-engagement interactions is particularly valuable; many frameworks gloss over scoping and legal authorization, which are precisely the areas where inexperienced testers make costly mistakes.

On the downside, PTES has **not been formally updated in several years**, and the technical guidance sections reference outdated tools and techniques. The methodology and phase structure remain sound, but testers should supplement PTES’s tool-specific guidance with current documentation. It also lacks the quantitative metrics of OSSTMM, so results depend more on the individual tester’s judgment.

Answer the questions below

Q 8- Which PTES phase number specifically addresses defining the scope, rules of engagement, and legal authorization for a penetration test?

Answer : 1

Task 6- **ISSAF**

Overview

Have you ever studied a vintage textbook and found that, despite its age, the core logic still holds up? In cyber security, tools and exploits have a short shelf life, but well-designed methodologies can outlast the technologies they were built to test. The **Information Systems Security Assessment Framework (ISSAF)** is a case in point.



Developed by the **Open Information Systems Security Group (OISSG)**, ISSAF is an open-source penetration testing framework designed to evaluate network, system, and application security. The latest version, **ISSAF v0.2.1**, was published around 2006, and the framework is **no longer actively maintained**. There is no longer an official URL to download it; however, the draft can still be found through archived sources online. This is important context: ISSAF’s methodology and phase structure remain instructive, but its tool-specific guidance is outdated and should not be relied upon for current engagements.

So why study a framework that is no longer maintained? Because ISSAF’s **nine-step assessment model** is one of the clearest representations of how an attacker progresses through a target environment. It mirrors the logic of an advanced persistent threat, moving systematically from initial reconnaissance to persistent access and the removal of evidence. If that progression sounds familiar, it should; it is the kill-chain thinking you have encounter in detail in the Cyber Kill Chain room earlier in this module.

ISSAF covers a broad range of security domains, including network infrastructure, host systems, web applications, databases, and social engineering. Its risk-based approach prioritizes high-impact, exploitable vulnerabilities over low-severity findings.

Phases: A Walkthrough

ISSAF divides an assessment into three phases. Let’s walk through them with a scenario: your team is assessing the security of **TechBridge Solutions**, a software

development company with 200 employees, an internal Git server, and a client-facing project management portal.

Phase 1: Planning and Preparation

This phase sets the engagement boundaries. You meet with TechBridge’s CTO to define the scope (corporate network, Git server, and the project management portal), establish escalation protocols and emergency contacts, identify constraints (the production Git server must not be disrupted during business hours), and agree on the toolset appropriate for the assessment.

Phase 2: Assessment

This is the core of ISSAF and where its nine-step model lives. Each step builds on the previous one, simulating how a real adversary would progress through the environment.

1. **Information gathering:** Collect publicly available data about TechBridge. DNS records, WHOIS data, employee profiles on LinkedIn, and technology references in job postings (“experience with Jenkins and GitLab CI required”) all feed your understanding of the target.
2. **Network mapping**: Map the live network topology. You discover TechBridge’s external IP range hosts the project portal, a VPN gateway, and a mail server. Internal scanning (once in scope) reveals the Git server, a Jenkins build server, and several developer workstations.
3. **Vulnerability identification**: Scan the mapped assets for weaknesses. The project portal runs an outdated CMS with a known authentication bypass. The Jenkins server has its administrative console exposed without authentication.
4. **Penetration**: Attempt initial exploitation. You exploit the unauthenticated Jenkins console to execute system commands on the build server.
5. **Gaining access and privilege escalation**: Escalate from initial access to higher privileges. From the Jenkins server, you recover stored credentials for the service account that deploys code to production, which has administrative rights on the Git server.
6. **Enumerating further**: With elevated access, enumerate what is now

reachable. From the Git server, you discover repositories containing API keys, database connection strings, and client project source code.

7. **Compromise remote users/sites (lateral movement)**: Move laterally to other systems. Using the harvested credentials, you access several developer workstations and the internal mail server.

8. **Maintaining access**: Establish persistent access to demonstrate that a real attacker could retain their foothold. You document (without actually deploying) how a backdoor could be planted in the CI/CD pipeline, persisting across system reboots and deployments.

9. **Covering tracks**: Demonstrate how an attacker would erase evidence. You document which logs captured your activity and identify gaps in TechBridge’s logging that would allow a real adversary to operate undetected.

Notice the progression: each step deepens the attacker’s position in the environment. Steps 1 through 3 are reconnaissance and analysis, steps 4 through 7 are active compromise, and steps 8 through 9 address persistence and stealth.

Phase 3: Reporting and Cleanup

You compile findings into a structured report, prioritized by business impact. The unauthenticated Jenkins console is flagged as critical because it provided the initial foothold that led to source code access. Cleanup involves removing any test artifacts, revoking any temporary accounts created during testing, and confirming with TechBridge’s team that no testing residue remains in their environment.

Closing Notes

ISSAF’s nine-step model is its lasting contribution. The progression from information gathering through lateral movement to covering tracks provides a clear mental model for how real-world attacks unfold, making it an excellent educational tool even though the framework itself is no longer maintained.

However, that unmaintained status is a real limitation. The tool-specific guidance references software versions that are over a decade out of date, and there is no community updating the documentation. ISSAF should be studied for its **methodology and adversarial logic**, not for its technical procedures. For current

tool guidance, supplement with resources such as PTES, OWASP WSTG, or the relevant tool documentation.

Answer the questions below

Q 9- ISSAF’s nine-step assessment model begins with information gathering. What is the ninth and final step?

Answer :

Task -7 **MITRE ATT&CK**

Overview

In the previous tasks, we explored frameworks that tell you *how to conduct* a penetration test: how to scope it, progress through phases, and report your findings. But consider this situation: you have just completed an engagement using PTES, and the report documents that you gained initial access through a phishing email, escalated privileges by exploiting a misconfigured service, moved laterally using stolen credentials, and exfiltrated data through an encrypted channel. Your client reads the report and asks a deceptively simple question: “How does our exposure compare to what real threat actors are actually doing in the wild?”

That question is difficult to answer with a penetration testing framework alone. Frameworks like PTES and OSSTMM structure your testing process, but they do not systematically catalog the specific tactics and techniques that real-world adversaries use. This is the gap that **MITRE ATT&CK** fills.

ATT&CK stands for **Adversarial Tactics, Techniques, and Common Knowledge**. Developed and maintained by MITRE Corporation, it is not a traditional penetration testing framework. It is a **knowledge base** of adversary behavior, built from real-world observations of how threat actors operate. It catalogs *what* attackers do, organized in a structure that security professionals can use for threat intelligence, detection engineering, red teaming, and, relevant to this room, enriching penetration test findings.

The Matrix: Tactics, Techniques, and Sub-Techniques

ATT&CK is organized as a **matrix**. Think of it as a large table. The **columns** represent **tactics**, which are the adversary’s high-level objectives, the *why* behind an action. The current Enterprise matrix includes 14 tactics, progressing from initial access through execution, persistence, privilege escalation, defense evasion, credential access, discovery, lateral movement, collection, command and control, exfiltration, and impact.

Within each tactic column, the **rows** list **techniques**, which are the *how*, the specific methods an adversary uses to achieve that tactical objective. For example, under the Initial Access tactic, you will find techniques like Phishing (`T1566`), Exploit Public-Facing Application (`T1190`), and Valid Accounts (`T1078`). Many techniques are further broken down into **sub-techniques**. Phishing, for instance, has sub-techniques for spearphishing attachments (`T1566.001`), spearphishing links (`T1566.002`), and spearphishing via service (`T1566.003`).

Each technique entry in the ATT&CK knowledge base includes a description, real-world examples of threat groups that have used it, detection recommendations, and mitigations. This is what makes ATT&CK more than a taxonomy; it is a living reference tied to observed adversary behavior.

ATT&CK as a Complement, Not a Replacement

Here is the key distinction for this room: ATT&CK does not tell you how to run a penetration test. It does not define phases, scoping procedures, or reporting formats. Instead, it provides a **common language** for describing what you found during a test conducted using any framework.

Consider the analogy of a medical dictionary versus a diagnostic procedure. PTES is like the diagnostic procedure: it tells the doctor what steps to follow during an examination. ATT&CK is like the medical dictionary: it provides standardized terminology for naming and categorizing what the doctor observes. You need both, but they serve different purposes.

Walkthrough: Mapping Findings to ATT&CK

Let’s see how this works in practice. Recall the MedGuard Health engagement from Task 5 (PTES). Here is how the key findings from that engagement map to ATT&CK technique IDs:

Engagement Finding	ATT&CK Tactic	ATT&CK Technique
Phishing email delivered payload to employee workstation	Initial Access	Phishing: Spearphishing Attachment (`T1566.001`)
Exploited Tomcat deserialization flaw on patient portal	Initial Access	Exploit Public-Facing Application (`T1190`)
Extracted cached domain credentials from workstation	Credential Access	OS Credential Dumping (`T1003`)
Moved from workstation to file server using stolen credentials	Lateral Movement	Use Alternate Authentication Material (`T1550`)
Accessed patient records database from compromised portal server	Collection	Data from Information Repositories (`T1213`)

By annotating a PTES report with ATT&CK technique IDs, the tester provides MedGuard’s security team with actionable insights beyond patching individual vulnerabilities. The client can now look up each technique in the ATT&CK knowledge base, review the detection guidance, and build or validate detection rules for those specific behaviors. The conversation shifts from “fix this one bug” to “can we detect this class of adversary behavior?”

Closing Notes

ATT&CK’s strength lies in its role as a **universal translator** of adversary behavior. It enables penetration testers, threat intelligence analysts, detection engineers, and incident responders to speak the same language. For penetration testers specifically, mapping findings to ATT&CK elevates a report from a list of vulnerabilities to a narrative grounded in real-world threat behavior.

The knowledge base is extensive, and mastering it takes time. The Enterprise matrix alone contains over 200 techniques. For a deeper, hands-on exploration of ATT&CK, including how to navigate the matrix, research specific threat groups, and apply it to detection engineering, dedicated rooms later in the TryHackMe platform cover ATT&CK in far greater detail. For now, the essential takeaway is this: ATT&CK complements your chosen penetration testing framework by providing a standardized vocabulary for what you find.

Answer the questions below

Q 10- In the ATT&CK matrix, what do the columns represent?

Answer : **tactics**

Q 11 -In the ATT&CK matrix, what do the rows within each column represent?

Answer : In the ATT&CK matrix, what do the rows within each column represent?

Q 12- You compromised a web server by exploiting an unpatched vulnerability in its public-facing application. What ATT&CK technique ID would you use to classify this finding?

Answer : T1190

Task 8- OTHER NOTABLE Frameworks

Overview

The frameworks we have covered so far, OSSTMM, OWASP WSTG, NIST SP 800–115, PTES, ISSAF, and MITRE ATT&CK, represent the core methodologies and knowledge bases a junior penetration tester is most likely to encounter. But the landscape does not end there. Depending on the industry, platform, or regulatory environment your client operates in, you may need to be aware of more specialized frameworks that address specific domains.

This task surveys five additional frameworks. The goal is not deep mastery of each one but **landscape awareness**: knowing they exist, understanding their niche, and recognizing when a client engagement might call for one of them.

The Frameworks

WASC Threat Classification was developed by the **Web Application Security Consortium (WASC)** as a taxonomy for categorizing web application vulnerabilities and attack types. It organizes threats into categories such as insufficient authentication, information leakage, and abuse of functionality. While it was influential in the mid-2000s and helped standardize how the industry discussed web threats, it has since been largely superseded by the OWASP Top Ten and WSTG as the dominant web security references. You may still encounter it referenced in older documentation or compliance frameworks.

CSA Cloud Controls Matrix(CCM) is published by the **Cloud Security Alliance (CSA)** and provides a cyber security controls framework specifically designed for **cloud computing environments**. It maps controls across 17 domains, including data security, identity and access management, and infrastructure security, and aligns them with major standards like ISO 27001, NIST, and PCI DSS. CCM is not a penetration testing methodology; it is a **governance and compliance tool** that helps organizations assess whether their cloud providers and configurations meet security requirements. You would encounter it when a client needs a cloud security posture assessment rather than a traditional pentest.

OWASP Mobile Application Security Testing Guide (MASTG) is the mobile counterpart to the WSTG we covered in Task 3. Maintained by OWASP, the MASTG provides detailed test cases for **Android and iOS application security**, covering areas like data storage, cryptographic implementation, network communication, platform interaction, and code quality. If your engagement involves testing a mobile banking app, a healthcare patient portal app, or any client-facing mobile application, the MASTG is the go-to reference. It is used alongside the **OWASP Mobile Application Security Verification Standard (MASVS)**, which defines the security requirements that the MASTG tests against.

PCI DSS Penetration Testing Guidelines are defined within the **Payment Card Industry Data Security Standard**, specifically in **Requirement 11.4** (PCI DSS v4.0). Unlike the general-purpose frameworks covered earlier, these guidelines are **regulatory mandates:** any organization that processes, stores, or transmits cardholder data must conduct penetration tests that meet PCI DSS criteria. The guidelines specify that tests must cover both the external perimeter and the internal network, must be conducted at least annually and after significant infrastructure changes, and must validate network segmentation controls. When your client is a retailer, payment processor, or any entity in the payment card ecosystem, PCI DSS requirements will shape both the scope and the reporting format of your engagement.

CBEST Framework was developed by the **Bank of England** in collaboration with the UK financial sector. It is a **threat-intelligence-led penetration testing framework** designed specifically for **UK financial institutions**, including banks, insurers, and financial market infrastructure providers. CBEST engagements

begin with a bespoke threat intelligence phase that identifies the most relevant threat actors and attack scenarios for the specific institution, and the subsequent penetration test simulates those realistic threat scenarios. CBEST is notable for its close integration of threat intelligence with hands-on testing and for its regulatory backing within the UK financial sector.

Comparison Table

Framework	Primary Domain	Type	Actively Maintained	When You Would Use It
WASC Threat Classification	Web applications	Threat taxonomy	No (superseded by OWASP)	Legacy references; historical context
CSA Cloud Control Matrix	Cloud environments	Governance/compliance controls	Yes	Cloud security posture assessments
OWASP Mobile Application Security Testing Guide	Mobile applications (Android/iOS)	Testing guide	Yes	Mobile app penetration testing
PCI DSS Penetration Testing Guidelines	Payment card environments	Regulatory mandate	Yes (current: PCI DSS v4.0)	Any engagement involving cardholder data
CBEST	UK financial sector	Threat-intel-led pen testing	Yes	Engagements with UK financial institutions

Closing Notes

The key takeaway from this survey is that **framework selection is driven by context**. The client’s industry, regulatory obligations, technology platform, and geographic jurisdiction all influence which framework applies. A penetration tester working with a UK bank must understand CBEST. A tester assessing a mobile health app will reach for OWASP MASTG. A tester working with a payment processor cannot avoid PCI DSS requirements. Knowing the landscape means you can recognize which framework a given engagement demands, even if you need to study it in detail at that point.

Answer the questions below

Q 13- Your client is a European online retailer that processes credit card payments through their website. Which framework from this task would most directly govern the penetration testing requirements for this engagement?

Answer : PCI DSS Penetration Testing Guidelines

Q 14- A client asks you to assess the security of their iOS banking application, including how it stores credentials locally and communicates with backend APIs. Which framework from this task is the most appropriate testing reference?

Answer : OWASP Mobile Application Security Testing Guide

Q 15- Your team is evaluating a client’s AWS infrastructure to determine whether their cloud configurations meet industry security standards. They are not asking for a penetration test but rather a controls assessment. Which framework is most relevant?

Answer : CSA Cloud Control Matrix

Task 9- Choosing The Right Framework

Overview

You now have a working knowledge of several penetration testing frameworks, each with its own philosophy, structure, and strengths. But knowing what each framework *is* does not automatically tell you which one to *use*. In practice, framework selection is one of the first decisions a penetration tester makes after receiving an engagement brief, and it is a decision shaped by multiple factors that often pull in different directions.

Consider the analogy of a mechanic’s toolbox. A mechanic does not use every tool on every job; they select tools based on the vehicle, the problem, and the customer’s expectations. A penetration tester operates the same way. The “right” framework depends on the client’s industry, the type of systems being tested, the regulatory landscape, and the engagement’s objectives.

This task walks through the key selection criteria and then presents realistic scenarios for you to practice the decision.

Selection Criteria

Four factors consistently drive framework selection in real-world engagements.

Engagement scope and target type is the most immediate filter. A web application assessment aligns with the OWASP WSTG. A mobile app engagement calls for OWASP MASTG. A full-spectrum network penetration test aligns

naturally with PTES or OSSTMM. If the scope spans multiple channels, including physical and human factors, OSSTMM’s five-channel model becomes particularly relevant.

Regulatory and compliance requirements can override personal preference entirely. If the client processes payment card data, PCI DSS penetration testing guidelines are not optional. If the client is a UK financial institution subject to Bank of England oversight, CBEST may be mandated. NIST SP 800–115 carries weight in U.S. government and federal contractor environments. When regulation dictates, the tester adapts.

Need for quantifiable, repeatable results matters when multiple assessors are involved or when results must be compared across time periods. OSSTMM’s RAV metrics are specifically designed for this. If a client says, “We want to measure whether our security posture has improved since last year’s test,” OSSTMM provides the measurement framework to objectively answer that question.

Team expertise and available resources are practical constraints that are easy to overlook. A full OSSTMM implementation requires deep familiarity with its metrics system. CBEST demands threat intelligence capabilities. For a smaller team conducting a standard corporate network assessment, PTES offers a practical, well-structured workflow without the overhead of more specialized frameworks.

Scenario Practice

Let’s apply these criteria to realistic situations. For each scenario, consider which framework (or combination) you would recommend and why.

Scenario 1:

A regional hospital hires your team to test their patient-facing web portal and the internal network it connects to. The hospital must comply with HIPAA, but is not subject to PCI DSS (it outsources payment processing). They want a structured, end-to-end assessment with a clear executive summary for the board of directors.

PTES is the strongest fit here. It provides the end-to-end engagement structure the hospital needs, its reporting phase explicitly produces both executive and technical deliverables, and it covers both web application and network testing

within a single methodology. OWASP WSTG can supplement the web portal testing specifically, and mapping findings to MITRE ATT&CK technique IDs would strengthen the report by grounding it in real-world threat behavior.

Scenario 2:

A multinational bank headquartered in London needs a penetration test that satisfies its UK regulatory obligations. The engagement must begin with a threat intelligence assessment specific to the institution.

CBEST is the clear choice. It is designed for UK financial institutions, mandates a bespoke threat intelligence phase, and is recognized by the Bank of England. No general-purpose framework alone would satisfy these requirements.

Scenario 3:

A SaaS startup wants two different security firms to independently test its platform over the next two years and compare the results directly to track improvement. The platform is entirely web-based.

OSSTMM’s RAV metrics enable direct cross-team, cross-time comparisons that the client is requesting. OWASP WSTG would guide the web-specific test cases, while OSSTMM provides the quantitative measurement layer that makes year-over-year comparison meaningful.

Scenario 4:

A fintech company asks you to test their Android and iOS mobile banking applications, both of which handle credit card transactions.

This engagement requires two frameworks working together. OWASP MASTG provides the test cases for mobile application security on both platforms. PCI DSS penetration testing guidelines must also be followed because the applications handle cardholder data. The tester needs to satisfy both the mobile-specific testing methodology and the regulatory mandate simultaneously.

Closing Notes

As these scenarios illustrate, framework selection is rarely a single choice. Real engagements often involve a **primary framework** that structures the overall

methodology and **supplementary frameworks** that address specific regulatory, platform, or reporting requirements. The ability to recognize which frameworks apply and how they complement each other is a skill that distinguishes a methodical penetration tester from someone who simply runs tools.

Answer the questions below

Q 16- A U.S. federal agency needs a security assessment of its internal network. The results must align with federal guidelines, and the assessment should include both document reviews and active penetration testing. Which framework is the most natural primary choice?

Answer : NIST SP 800–115

Q 17- Your client is an e-commerce company with a web storefront, a mobile shopping app, and a payment processing system. Which combination of frameworks would you recommend to cover all three components? (comma-separrated)

Answer : WSTG,MASTG,PCI DSS

Task 10- Conclusion

In this room, we explored the landscape of penetration testing frameworks, moving from the question “why do frameworks matter?” to the practical skill of selecting the right one for a given engagement.

To continue with the practical challenge, press the **View Site** button below.

We began with **OSSTMM** and its scientific, metrics-driven philosophy, where security is not a subjective opinion but a measurable property expressed through Risk Assessment Values. We then examined **OWASP WSTG**, the web application tester’s roadmap, with its 90+ test cases organized across the Software Development Life Cycle. **NIST SP 800–115** showed us how security testing fits into the government and enterprise world, structuring assessment techniques from passive document review through active exploitation. **PTES** brought us closest to

the day-to-day reality of penetration testing, mapping seven phases from the first client call to the final report. **ISSAF**, though no longer maintained, gave us one of the clearest models of adversarial progression through its nine-step assessment. And **MITRE ATT&CK** provided the common vocabulary for describing what adversaries actually do, enriching findings from any framework with technique IDs grounded in real-world threat intelligence.

We surveyed five additional frameworks, each serving a specialized niche, from mobile application testing (OWASP MSTG) to regulatory mandates in the payment card industry (PCI DSS) and the UK financial sector (CBEST). Finally, we practiced the applied skill of framework selection, recognizing that real engagements often require a primary methodology supplemented by domain-specific or regulatory frameworks.

Master Comparison Table

Framework	Scope	Key Strength	Limitation	Best For
OSSTMM	Multi-channel (5 channels)	Quantifiable metrics (RAVs)	Steep learning curve	Repeatable, auditable assessments
OWASP WSTG	Web applications	90+ structured test cases	Can encourage checklist mentality	Web app penetration testing
NIST SP 800-115	Systems, networks, applications	Federal credibility; flexible technique categories	Guidance only, no enforcement	Government and enterprise assessments
PTES	End-to-end engagements	Practical, phase-driven workflow	Not recently updated	Standard network/application pentests
ISSAF	Networks, systems, applications	Clear nine-step adversarial progression	No longer maintained	Educational reference for attack methodology
MITRE ATT&CK	Adversary behavior catalog	Universal language for threat behavior	Not a testing methodology	Enriching findings from any framework
OWASP MSTG	Mobile applications (Android/iOS)	Platform-specific mobile test cases	Mobile-only scope	Mobile app security testing
PCI DSS Guidelines	Payment card environments	Regulatory mandate	Narrow applicability	Engagements involving cardholder data
CSA CCM	Cloud environments	Governance controls mapped to major standards	Not a penetration testing methodology	Cloud security posture assessments
CBEST	UK financial sector	Threat-intel-led, regulatory backing	UK financial sector only	UK financial institution engagements
WASC Threat Classification	Web applications	Historical taxonomy	Superseded by OWASP	Legacy reference only

What Comes Next

This room focused on the frameworks that structure *how* penetration tests are planned, executed, and reported. In the Pentesting Methodologies and Reporting module, we cover Threat Modeling for Pentesters and Planning and Scoping. Those rooms will formalize it further, giving you the adversarial mindset that complements the methodological discipline you have built here.

Answer the questions below

Q 18- Go through the attached static site. What is the flag?

Answer : THM{pen-test-fr4m3work5}

happy hacking

Nuh hozar - Medium

Read writing from Nuh hozar on Medium. Whatever is in the name of goodness and beauty, those who know us know, those...

nuhhozar.medium.com

nuh hozar block sayfası

https://nuhhozar.blogspot.com

nuhhozar.blogspot.com

https://github.com/NuhHozar/

Pen Testing Frameworks +



Follow

Written by Nuh hozar

5 followers · 9 following

Whatever is in the name of goodness and beauty, those who know us know, those who don't know know as well as themselves.!!